



[Home](#) / [Be compliant](#) /

Data Protection Officer

On this page

What is a DPO and does your organisation need one?

Who can be DPO in my organisation?

What is a DPO and does your organisation need one?

What is a DPO and what do they do?

The data protection officer (also referred to as “DPO”) is a data protection expert who advises on data protection compliance within an organisation.

The DPO needs to be involved, properly and in a timely manner, in all issues which relate to the protection of personal data.

According to GDPR, the tasks of the DPO are, at least, the following ones:

- to inform and advise the organisation and its employees on data protection compliance;
- to monitor data protection compliance;
- to provide advice on requests concerning the data protection impact assessment (DPIA) ;
- to act as a contact point for the data protection authority (DPA) and to cooperate with that DPA;
- to act as a contact point for individuals.

The DPO’s presence is generally recommended where decisions with data protection implications are taken. The DPO must also be promptly consulted once a data breach or another incident has occurred.

In practice, the DPO is also often assigned by the data controller or the data processor with the task of maintaining the record of processing operations.

[Read more](#)

Does my organisation need a DPO?

The appointment of a DPO is mandatory in the following three cases:

- the organisation is a public authority that carries out the processing of personal data;

- the organisation's core activities consist in regular and systematic monitoring of individuals on a large scale, for example geolocation via a mobile application, or surveillance of shopping centres and public spaces through CCTV;
- the organisation's core activities consist in large-scale [processing of sensitive data](#).

The notions of "core activities", "regular and systematic monitoring" and "large-scale" are crucial in determining whether an organisation should appoint a DPO.

"Core activities" means that the processing operations are key to achieve the data controller's or processor's objectives. These also include all activities where the processing of data forms an inextricable part of the data controller or processor's activity.

"Large-scale" depends on different factors, such as the volume of the data processed, the number of individuals concerned - either as a specific number or as a proportion of the relevant population, the duration and the geographical scope of the processing.

"Regular and systematic monitoring" includes all forms of tracking and profiling on the internet, including for the purposes of behavioural advertising. However, the notion of monitoring is not restricted to the online environment.

In practice

- **Core activities**

For example, the core purpose of a clinic is to provide health services to individuals. In this case, processing health data, such as patients' health records, should be considered as one of the organisation's core activities.

However, all organisations carry out certain supporting activities, for example, paying their employees or carrying out standard IT support activities. These are examples of necessary support functions for the organisation's core activity or main

business. Even though these activities are necessary or essential, they are usually considered ancillary functions rather than the core activity.

- **Large-scale**

Examples of large-scale processing include for instance:

1. the processing of patient's data as part of the day-to-day activities of a hospital;
2. the processing of customer data in the context of day-to-day activities of an insurance company or a bank;
3. the processing for statistical purposes of current location data of customers of an international fast-food chain by a subcontractor specialised in such services;
4. processing of personal data for behavioural advertising by a search engine;
5. the processing of data (content, flow, location) by telephone and Internet service providers.

Examples of processing that **would not be considered** as large-scale:

1. processing of patient data by a single general practitioner;
2. processing of personal data relating to convictions and offences by an individual lawyer.

- **Regular and systematic monitoring**

For example, regular and systemic monitoring covers email retargeting; data-driven marketing activities; profiling and scoring for purposes of risk assessment (e.g. for purposes of credit scoring, establishment of insurance premiums, fraud prevention, detection of money-laundering); location tracking (for example, by mobile apps); loyalty programs; behavioural advertising; monitoring of wellness, fitness and health data via wearable devices; CCTV; connected devices (e.g. smart meters), smart cars, home automation, etc.

As such, a processor having as core activity to provide website analytics services and assistance with targeted advertising and marketing will have to appoint a DPO.

You can always appoint a DPO on a voluntary basis, even if this is not legally required. Please note that in that case, you must comply with all the provisions of the GDPR concerning the tasks and position of the data protection officer. Therefore, it is advised to only use the title of DPO for a person whose function and position matches the description of the GDPR.

[Read more](#)

Who can be DPO in my organisation?

The DPO must be able to perform their duties and tasks in an independent manner. This means that your organisation:

- may not give instructions to the DPO with regard to the performance of their DPO duties;
- may not penalise or dismiss the DPO for performing their tasks.

The autonomy of DPOs does not, however, mean that they have decision-making powers extending beyond their tasks. Organisations remain responsible for the compliance with data protection law and must be able to demonstrate compliance.

The DPO should be seen as a discussion partner within the organisation and should be part of the discussions dealing with data processing activities within the organisation.

DPOs shall directly report to the highest management level of the data controller or the processor.

DPOs can fulfil other tasks within the organisation, but it cannot result in a conflict of interest. This implies that the DPO cannot have a position in which they determine the purposes and means of the processing activities of personal data. Conflicting functions include mainly management positions (chief executive, chief operating, chief financial officer, Head of HR, Head of IT, managing director) but may also involve other functions if they lead to the determination of purposes and means of processing.

It is possible under the GDPR to appoint an external DPO with a contract for their services. This contract may be concluded with an individual or an organisation. In this latter case, it is essential that each member of the organisation does not have a conflict of interest and is protected against any unfair termination of service contract, but also against unfair dismissal of any individual member of the organisation for activities as DPO.

Your organisation should assist the DPO by providing access to any processing operations, as well as to any personal data processed in the context of these processing operations. It is crucial that the DPO is involved from the earliest stage possible in all issues relating to data protection. The necessary resources should also be made available for the DPO to carry out their duties (time, training, equipment and financial means).

In practice

In performing their tasks, DPOs must not be instructed as to how to deal with a matter. For example, the DPO should not be given instructions on what the result of their advice should be, or on how they have to investigate a complaint of an individual, or on whether the consultation of the data protection authority is appropriate or compulsory. Furthermore, the DPO must not be instructed to take a certain point of view on an issue related to data protection law, for example, a particular interpretation of the law.

[Read more](#)

Checklist for appointing a DPO

- **Check whether or not a DPO is required:** Check whether you need to appoint a DPO and, if in doubt, document the reasons why you do or do not appoint a DPO.
- **If a DPO is required:**
 - **Decide between an internal or external DPO:** If a DPO is required, decide if it will be a member of your organisation or a DPO on the basis of a service contract;

- **Verify that the DPO has the professional qualities and expertise in data protection** law and practices, and the ability to fulfil the tasks;
 - **Verify independence requirements:** Check whether your DPO has other duties that could compromise their independence in the performance of their tasks (conflicts of interest);
 - **Develop standard procedures** within your organisation's governance for the involvement of the DPO.
- **If a DPO is not required:**
 - **Think it through:** Even if you do not appoint a DPO in the sense of the GDPR, you will still need to comply with a number of data protection requirements. We advise you to appoint a DPO on a voluntary basis, or a person not having the title of DPO who, even if they do not fully exercise the tasks of a DPO, monitors compliance and acts as a contact person for individuals exercising their data subject rights.

[Back to EDPB](#)

[Career opportunities](#)

[Copyright](#)

[Cookies](#)

[General Data Protection Notice](#)

